

Dag 3
Compliance
NIS 2 og ISO 27000



NIS 2

(Network and Information Systems)

- Hvad er NIS 2?
- National implementering i DK
- Hvem er omfattet af NIS 2?
- NIS 2 compliance

Hvad er NIS 2?

Er der nogen, der vil give et bud på, hvad NIS 2 er?

Hvad er NIS 2?

- NIS 2 står for “Network and Information Systems” eller på dansk “Net- og Informationssystemer”.
- Det er et EU-direktiv, der fastlægger foranstaltninger til sikring af et højt fælles cybersikkerhedsniveau i EU.
- NIS 2-direktivet bygger ovenpå og ophæver EU-direktivet om sikkerhed i net- og informationssystemer (NIS 1-direktivet).
- NIS 2-direktivet blev vedtaget i december 2022.

Kilde: Styrelsen for Samfundssikkerhed

Hvad er NIS 2?

- Formålet er at styrke og ensarte cybersikkerheden og modstandsdygtigheden over for cybertrusler på tværs af EU for virksomheder inden for en lang række sektorer og for offentlige myndigheder, som anses for at være kritiske for økonomien og samfundet.
- Med NIS 2 indføres en række krav til omfattede virksomheder og myndigheder. NIS 2 stiller bl.a. krav om gennemførelse af cybersikkerhedsforanstaltninger, hændelsesrapportering samt giver styrkede tilsyns- og håndhævelsesbeføjelser.

Kilde: Styrelsen for Samfundssikkerhed

Nationalt implementering i DK

- EU-direktiver skal efterleves af alle mellemstater og implementeres via national lovgivning – altså via dansk lov.
- **Den dansk NIS 2-lov:** Loven om foranstaltninger til sikring af et højt cybersikkerhedsniveau.
- Vedtaget maj 2025 med virkning fra juni samme år.
- Den dansk NIS 2-lov er stort set NIS 2-direktivet - bare skrevet lidt anderledes.
- Lige pt. ligger ansvaret for den nationale implementering hos SAMSIK.

Hvem er omfattet af NIS 2?

Der opereres med:

- Særligt kritiske sektorer og kritiske sektorer
- Væsentlige enheder og vigtig enheder*

NIS 2-LOVEN

NIS 2-loven er en del af den danske implementering af EU's NIS 2-direktiv. NIS 2-direktivet implementeres ved særskilte love for tele-, energi- og finanssektoren.

Formålet med NIS 2-direktivet er at styrke og ensarte cybersikkerheden og modstandsdygtigheden overfor cybertrusler på tværs af EU for virksomheder inden for en lang række sektorer og for offentlige myndigheder, som anses for at være kritiske for samfundet og økonomien.

Enheder omfattet af NIS 2-loven har selv ansvaret for at vurdere, om de er omfattet af lovgivningen, og i givet fald registrere sig hos den relevante sektoransvarlige myndighed. Omfattede enheder vil ikke blive udpeget af de sektoransvarlige myndigheder.

Der er nogle klare kriterier for ovenstående – det kommer vi ikke ind på.

En enhed er enhver **offentlig eller privat organisation, der leverer en tjeneste eller udfører en aktivitet inden for de sektorer, som er oplistet i NIS 2-direktivet og den danske NIS 2-lov*

NIS 2 compliance

- Det er enhedens eget ansvar at sikre overholdelse med NIS 2-loven.
- Styrelsen for Samfundssikkerhed (SAMSIK) har udgivet nogle vejledninger, der kan anvendes:
 - Vejledning om anvendelsesområdet
 - Vejledning om ledelsens rolle og opgaver
 - Vejledning om foranstaltninger
 - Vejledning om hændelsesunderretning



NIS 2 compliance

- Compliance med NIS 2-loven kan sikres via ISO 27000-serien:
 - ISO 27001 efterlevelse uden certificering
 - ISO 27001 certificeret
- Så er enheden næsten i compliance – nogle områder er *ikke* dækket af ISO 27001.

NIS 2 compliance

- NIS2-krav **ikke** dækket af ISO 27001:
 - Juridiske krav og myndighedsforpligtelser (registrering, tilsyn, påbud, sanktioner)
 - Incident-rapportering til myndigheder (24 / 72 timer og slutrapport)
 - Personligt ledelsesansvar (bestyrelsesansvar, ledelsesgodkendelse, evt. sanktioner)
 - Sektor- og samfundskritisk fokus (forsyningssikkerhed, nationale trusler)
 - Udvidede leverandør- og forsyningskædekrav (kritiske leverandører, tredjelande)
 - Bøder og håndhævelse (administrative sanktioner, omsætningsbaserede bøder)

ISO 27000

- Hvad er ISO 27000-serien?
- ISO 27001 og 27002
- Anneks A, foranstaltninger

Hvad er ISO 27000-serien?

Er der nogen, der vil give et bud på, hvad ISO 27000-serien er?

Hvad er ISO 27000-serien?

- **ISO/IEC 27000-serien*** er en international samling af standarder for informationssikkerhed.
- **ISO/IEC 27000-serien** definerer best practice for styring af informationssikkerhed gennem et ledelsessystem (ISMS).
- **Formålet** er at beskytte informationer mod fx uautoriseret adgang, tab og misbrug samt at sikre *fortrolighed, integritet og tilgængelighed*.

**ISO (International Organization for Standardization) og IEC (International Electrotechnical Commission)*

Hvad er ISO 27000-serien?

The ISO/IEC 27000 Family of Standards

Vocabulary	ISO/IEC 27000 Overview and vocabulary				
Requirements	ISO/IEC 27006 Bodies providing audit and certification of ISMSs	ISO/IEC 27001 Information security management systems	ISO/IEC 27701 Privacy information management systems		
General guides	ISO/IEC 27002 Information security controls	ISO/IEC 27003 ISMS guidance	ISO/IEC 27004 Monitoring, measurement, analysis, and evaluation	ISO/IEC 27005 Managing information security risks	ISO/IEC 27007 and ISO/IEC TS 27008 ISMS audit guidance and assessment of information security controls
Industry guides	ISO/IEC 27011 Telecommunications organizations	ISO 27799 Health informatics		Other standards of the ISO/IEC 27000 family	

- De mest kendte standarder i serien er ISO 27001, som er kravene, mens ISO 27002 er vejledningen for sikkerhedsforanstaltninger.

ISO 27001 og 27002

- **ISO 27001** specificerer kravene til etablering, implementering, vedligeholdelse og løbende forbedring af et ledelsessystem for informationssikkerhed (ISMS).
- Altså kravet til ISMS 'en

- **ISO 27002** giver et referencesæt af generiske kontroller for informations-sikkerhed, herunder vejledning i implementering.
- Altså foranstaltninger der skal tages stilling til og behandles – der er 93 i alt.

ISO 27001 og 27002

- **ISO 27001** er rammeværket og definerer, som nævnt, kravene til ISMS ´en.
- Hvis en organisation påberåber sig overensstemmelse med ISO 27001, skal alle kravene være opfyldt og dokumenteret.
- Dvs. der skal være implementeret et velfungerende ISMS inklusiv stillingstagen til anneks A ´s 93 foranstaltninger
- Anneks A bliver til organisations SoA*

*SoA: *Statement of applicability (Anvendelseserklæring)*

ISO 27001-certificering

Opfyldelse af kravene kræver audit udført af et uafhængigt tredjeparts-certificeringsorgan.

ISO 27001 og 27002

- **ISO 27001** kravene fordeler sig på 7 områder:

- 4. Organisationens rammer og vilkår
- 5. Lederskab
- 6. Planlægning
- 7. Support
- 8. Drift
- 9. Evaluering af performance
- 10. Forbedringer

Indholdsfortegnelse (EN)		Side
Forord		iv
Indledning		v
1 Anvendelsesområde		1
2 Normative referencer		1
3 Termer og definitioner		1
4 Organisationens rammer og vilkår		1
4.1 Forståelse af organisationen og dens rammer og vilkår		1
4.2 Forståelse af interessenters behov og forventninger		1
4.3 Bestemmelse af omfanget af ledelsessystemet for informationssikkerhed		2
4.4 Ledelsessystem for informationssikkerhed		2
5 Lederskab		2
5.1 Lederskab og forpligtelse		2
5.2 Politik		2
5.3 Roller, ansvar og beføjelser i organisationen		3
6 Planlægning		3
6.1 Handlinger til adressering af risici og muligheder		3
6.1.1 Generelt		3
6.1.2 Vurdering af informationssikkerhedsrisici		4
6.1.3 Håndtering af informationssikkerhedsrisici		4
6.2 Målsætninger for informationssikkerhed og planlægning for opfyldelse heraf		5
7 Support		6
7.1 Ressourcer		6
7.2 Kompetencer		6
7.3 Awareness		6
7.4 Kommunikation		6
7.5 Dokumenteret information		6
7.5.1 Generelt		6
7.5.2 Udarbejdelse og opdatering		7
7.5.3 Styring af dokumenteret information		7
8 Drift		7
8.1 Driftsplanlægning og -styring		7
8.2 Vurdering af informationssikkerhedsrisici		8
8.3 Håndtering af informationssikkerhedsrisici		8
9 Evaluering af performance		8
9.1 Overvågning, måling, analyse og evaluering		8
9.2 Intern audit		8
9.2.1 Generelt		8
9.2.2 Internt auditprogram		9
9.3 Ledelsens evaluering		9
9.3.1 Generelt		9
9.3.2 Input til ledelsens evaluering		9
9.3.3 Resultater af ledelsens evaluering		9
10 Forbedring		10
10.1 Løbende forbedring		10
10.2 Afgivelse og korrigerende handling		10
Anneks A (normativt) Reference til foranstaltninger til informationssikkerhed		11
Bibliografi		19

- Det er med baggrund heri, at ISMS'en etableres og dokumenteres

ISO 27001 og 27002

- **ISO 27001** anneks A indeholder 93 definerede foranstaltninger fordelt på følgende områder:
 - Organisatoriske foranstaltninger (37 foranstaltninger)
 - Personrelaterede foranstaltninger (8 foranstaltninger)
 - Fysiske foranstaltninger (13 foranstaltninger)
 - Teknologiske foranstaltninger (34 foranstaltninger)
- **ISO 27002** er et referencesæt (vejledning) til fastlæggelse og implementering af foranstaltningerne for informationssikkerhedsrisici i ISMS'en.

Anneks A, foranstaltninger

- Vi vil ikke gennemgå alle 93 foranstaltninger, men lave et par nedslag under de teknologiske foranstaltninger.

A.8.2	Privilegerede adgangsrettigheder	A.8.16	Overvågning af aktiviteter
A.8.5	Sikker autentifikation	A.8.18	Brug af privilegerede understøttende programmer
A.8.8	Styring af teknisk sårbarhed	A.8.23	Webfiltrering
A.8.13	Backup af information	A.8.24	Brug af kryptografi
A.8.15	Logning	A.8.26	Krav til applikationssikkerhed

A.8.1	Brugerenheder
A.8.10	Sletning af informationer
A.8.11	Datamaskering
A.8.20	Netværkssikkerhed

Øvelse Setup



Øvelse 1 (Anneks A)

ISO 27001 A.8.2

A.8.2	Privilegerede adgangsrettigheder	Tildeling og anvendelse af privilegerede adgangsrettigheder skal begrænses og styres.		
-------	---	---	--	--

ISO 27002 (attributtabel)*

Foranstaltningstype	Informationssikkerhedsegenskaber	Cybersikkerhedsbegreber	Driftsmæssigekapaciteter	Sikkerhedsdomæner
#Forebyggende	#Fortrolighed #Integritet #Tilgængelighed	#Beskyt	#Identitetsstyring og adgangstyring	#Beskyttelse

Formål: At sikre, at kun autoriserede bruger, softwarekomponenter og -tjenester har privilegerede adgangsrettigheder.

**De 5 attributtyper i attributtabelen bliver ikke gennemgået*

Øvelse 1 (Anneks A)

ISO 27001 A.8.2

A.8.2	Privilegerede adgangsrettigheder	Tildeling og anvendelse af privilegerede adgangsrettigheder skal begrænses og styres.	Anvendelig	Procedure for adgangsrettigheder for informationsaktiver Retningslinje for IT-sikkerhed Retningslinje for brug af IT-faciliteter
-------	---	---	------------	--

ISO 27002 (attributtabel)*

Foranstaltningstype	Informationssikkerhedsegenskaber	Cybersikkerhedsbegreber	Driftsmæssigekapaciteter	Sikkerhedsdomæner
#Forebyggende	#Fortrolighed #Integritet #Tilgængelighed	#Beskyt	#Identitetsstyring og adgangstyring	#Beskyttelse

Formål: At sikre, at kun autoriserede bruger, softwarekomponenter og -tjenester har privilegerede adgangsrettigheder.

**De 5 attributtyper i attributtabelen bliver ikke gennemgået*

Øvelse 1 (Opgave)

- Hvordan kunne en procedure for privilegerede adgangsrettigheder se ud?
- Hvilke teknologier kan man bruge til at udføre sådan procedure?

Øvelse 2 (Anneks A)

ISO 27001 A.8.5

A.8.5	Sikker autentifikation	Der skal implementeres sikre autentifikationsteknologier og -procedurer på baggrund af begrænsninger i informationsadgangene og den emnespecifikke politik for administration af adgange.	Anvendelig	Procedure for adgangsrettigheder for informationsaktiver Retningslinje for IT-sikkerhed Retningslinje for brug af IT-faciliteter
-------	------------------------	---	------------	--

ISO 27002 (attributtabel)

Foranstaltningstype	Informationssikkerhedsegenskaber	Cybersikkerhedsbegreber	Driftsmæssigekapaciteter	Sikkerhedsdomæner
#Forebyggende	#Fortrolighed #Integritet #Tilgængelighed	#Beskyt	#Identitetsstyring og adgangstyring	#Beskyttelse

Formål: At sikre, at en bruger eller en entitet autentificeres på sikker vis, når der gives adgang til systemer, applikationer og tjenester.

Øvelse 2 (Opgave)

- Hvordan kunne en procedure for sikker autentifikation se ud?
- Hvordan relaterer denne kontrol sig til tidligere tekniske opgaver?

Øvelse 3 (Anneks A)

ISO 27001 A.8.8

A.8.8	Styring af teknisk sårbarhed	Der skal indhentes informationer om teknisk sårbarhed i anvendte informationssystemer, organisationens eksponering for sådanne sårbarheder skal evalueres, og der skal iværksættes passende tiltag.	Anvendelig	Procedure for kontakt til myndigheder og interessegrupper. Retningslinje for håndtering af kontakt til myndigheder og interessegrupper samt overvågning af trusler).
-------	------------------------------	---	------------	---

ISO 27002 (attributtabel)

Foranstaltningstype	Informationssikkerhedsegenskaber	Cybersikkerhedsbegreber	Driftsmæssigekapaciteter	Sikkerhedsdomæner
#Forebyggende	#Fortrolighed #Integritet #Tilgængelighed	#Identifier #Beskyt	#Trussels og sårbarhedsstyring	#Ledelse og økosystem #Beskyttelse #Forsvar

Formål: *At forhindre, at tekniske sårbarheder udnyttes.*

Øvelse 3 (Opgave)

- Hvordan kunne en procedure for styring/håndtering af tekniske sårbarheder se ud?
- Hvilke tekniske foranstaltninger hjælper her?

Øvelse 4 (Anneks A)

ISO 27001 A.8.13

A.8.13	Backup af information	Backup af information, software og systemer skal vedligeholdes og testes regelmæssigt i overensstemmelse med den aftalte emnespecifikke politik for backup.	Anvendelig	Intern IT har en proces for backup implementeret. Intern IT registrering for Alexandra backup overview. Indgår også som en århjul opgave i Intern IT. Retningslinje for IT sikkerhed.
--------	-----------------------	---	------------	--

ISO 27002 (attributtabel)

Foranstaltningstype	Informationssikkerhedsegenskaber	Cybersikkerhedsbegreber	Driftsmæssigekapaciteter	Sikkerhedsdomæner
#Afhjælpnde	#Integritet #Tilgængelighed	#Retabler	#Kontinuitet	#Beskyttelse

Formål: *At muliggøre retablering efter tab af data eller systemer.*

Øvelse 4 (Opgave)

- Hvordan kunne en proces se ud?
- Hvordan relaterer denne kontrol sig til tidligere tekniske opgaver?

Øvelse 5 (Anneks A)

ISO 27001 A.8.15

A.8.15	Logning	Logge, der optegner aktiviteter, undtagelser, fejl og andre relevante hændelser, skal udarbejdes, opbevares, beskyttes og analyseres.	Anvendelig	Procedure for logning
--------	---------	---	------------	-----------------------

ISO 27002 (attributtabel)

Foranstaltningstype	Informationssikkerhedsegenskaber	Cybersikkerhedsbegreber	Driftsmæssigekapaciteter	Sikkerhedsdomæner
#Opdagende	#Fortrolighed #Integritet #Tilgængelighed	#Opdag	#Styring af informationssikkerhedshændelser	#Beskyttelse #Forsvar

Formål: At optegnehændelser, genere bevismateriale, sikre logininformationens integritet, forhindre uautoriseret adgang, identificere hændelser, der kan føre til en sikkerhedsincident og understøtte undersøgelser.

Øvelse 5 (Opgave)

- Hvordan kunne en procedure for logning se ud?
- Hvordan relaterer denne kontrol sig til tidligere tekniske opgaver?

Øvelse 6 (Anneks A)

ISO 27001 A.8.16

A.8.16	Overvågning af aktiviteter	Netværk, systemer og applikationer skal overvåges for unormal adfærd, og der skal iværksættes passende handlinger for at evaluere potentielle informationssikkerhedsincidents.	Anvendelig	
--------	----------------------------	--	------------	--

ISO 27002 (attributtabel)

Foranstaltningstype	Informationssikkerhedsegenskaber	Cybersikkerhedsbegreber	Driftsmæssigekapaciteter	Sikkerhedsdomæner
#Opdagende #Afhjæpende	#Fortrolighed #Integritet #Tilgængelighed	#Opdag #Reager	#Styring af informationssikkerhedshændelser	#Forsvar

Formål: *At opdage unormal adfærd og potentielle informationssikkerhedsincidents.*

Øvelse 6 (Opgave)

- Hvordan kunne en proces for overvågning/monitorering se ud?
- Hvordan relaterer denne kontrol sig til tidligere tekniske opgaver?

Øvelse 7 (Anneks A)

ISO 27001 A.8.18

A.8.18	Brug af privilegerede understøttende programmer	Brugen af understøttende programmer, der kan omgå system- og applikationsforanstaltninger, skal begrænses og styres effektivt.	Anvendelig	Privilegeret adgang til servere er begrænset til systemadministratorer. På personlige computerer har medarbejderer administrator rettigheder.
--------	---	--	------------	---

ISO 27002 (attributtabel)

Foranstaltningstype	Informationssikkerhedsegenskaber	Cybersikkerhedsbegreber	Driftsmæssigekapaciteter	Sikkerhedsdomæner
#Forebyggende	#Fortrolighed #Integritet #Tilgængelighed	#Beskyt	#System og netværkssikkerhed #Sikker konfiguration #Applikationssikkerhed	#Beskyttelse

Formål: At sikre, at brugen af understøttende programmer ikke skader system og applikationsforanstaltninger til informationssikkerheden

Øvelse

Tekniske foranstaltninger

SUDOers file



Øvelse 8 (Anneks A)

ISO 27001 A.8.23

A.8.23	Webfiltrering	Adgang til eksterne websider skal styres for at reducere eksponering for skadeligt indhold.	Anvendelig	Der bruges cloudflare (1.1.1.1) i router og vpn. Cloudflare har automatiske blokering af ondsindede IP'er. I Microsoft 365 er ATP safe links slået til.
--------	---------------	---	------------	--

ISO 27002 (attributtabel)

Foranstaltningstype	Informationssikkerhedsegenskaber	Cybersikkerhedsbegreber	Driftsmæssigekapaciteter	Sikkerhedsdomæner
#Forebyggende	#Fortrolighed #Integritet #Tilgængelighed	#Beskyt	#System og netværkssikkerhed	#Beskyttelse

Formål: At beskytte systemer mod at blive kompromitteret af malware og at forhindre adgang til uautoriserede webressourcer.

Øvelse

Tekniske foranstaltninger

Webfiltrering



Øvelse 9 (Anneks A)

ISO 27001 A.8.24

A.8.24	Brug af kryptografi	Regler for effektiv anvendelse af kryptografi, herunder administration af krypteringsnøgler, skal identificeres og implementeres.	Anvendelig	Personlige devices: Retningslinje for IT sikkerhed. Servere: Altid krypteret, nøgler opbevares i 1Password.
--------	---------------------	---	------------	--

ISO 27002 (attributtabel)

Foranstaltningstype	Informationssikkerhedsegenskaber	Cybersikkerhedsbegreber	Driftsmæssigekapaciteter	Sikkerhedsdomæner
#Forebyggende	#Fortrolighed #Integritet #Tilgængelighed	#Beskyt	#Sikker konfiguration	#Beskyttelse

Formål: At korrekt og effektiv anvendelse af kryptografi for at beskyttet fortrolighed, autenticitet eller integritet af informationer i henhold til forretnings- og informations-sikkerhedskrav og under hensyntagen til juridiske, lovmæssige, regulatoriske og kontraktlige krav i relation til kryptografi.

Øvelse 9 (Opgave)

- Hvordan kunne en proces for brug af kryptografi se ud?

Øvelse 10 (Anneks A)

ISO 27001 A.8.26

A.8.28	Krav til applikationssikkerhed	Informationssikkerhedskrav skal identificeres, specificeres og godkendes ved udvikling eller anskaffelse af applikationer.	Anvendelig	Indgår i vores proces for risikovurdering af informationsaktiver. Systemer fra leverandører håndteres som beskrevet i proceduren for leverandørstyring. Procedure for risikovurdering af informationsaktiver Procedure for leverandørstyring
--------	--------------------------------	--	------------	--

ISO 27002 (attributtabel)

Foranstaltningstype	Informationssikkerhedsegenskaber	Cyversikkerhedsbegreber	Driftsmæssige kapaciteter	Sikkerhedsdomæner
#Forebyggende	#Fortrolighed #Integritet #Tilgængelighed	#Beskyt	#Applikationssikkerhed #System og netværkssikkerhed	#Beskyttelse #Forsvar

Formål: At sikre, at alle informationssikkerhedskrav identificeres og håndteres ved udvikling ved udvikling eller anskaffelse af applikationer.

Øvelse 10 (Opgave)

- Hvad kunne krav for sikker udvikling være?